



GAP ANALYSIS REPORT

PREPARED FOR

Summit Ridge Outfitters

PREPARED BY

Peter Van Cleave

May 17, 2026

CSS 2754 - Host Security

Purpose, Scope, and Objectives

Purpose:

In this report are findings of a targeted host security assessment prepared for Summit Ridge Outfitters. The goal is to identify gaps in security controls by performing a vulnerability scan on a host system and conducting an on-site physical security review.

Scope:

The assessment focused on one main host system (A Linux server mimicking Summit Ridge Outfitters' endpoint environment). A Nessus vulnerability scan was performed as well as physical security observations being documented from the store location. The assessment analyzed controls against the NIST 800-53 control set provided.

Objectives:

1. Discover and identify technical vulnerabilities using automated scanning with Nessus.
2. Document physical security weaknesses.
3. Map findings to specific security controls.
4. Provide actionable recommendations for remediation.

Summary Of Gap Analysis Methods

A vulnerability scan was conducted using Tenable's Nessus Essentials against a Metasploitable 2 host (IP: 192.168.56.101). The scan identified 56 vulnerabilities which included multiple of critical severity.

Scan Findings Summary:

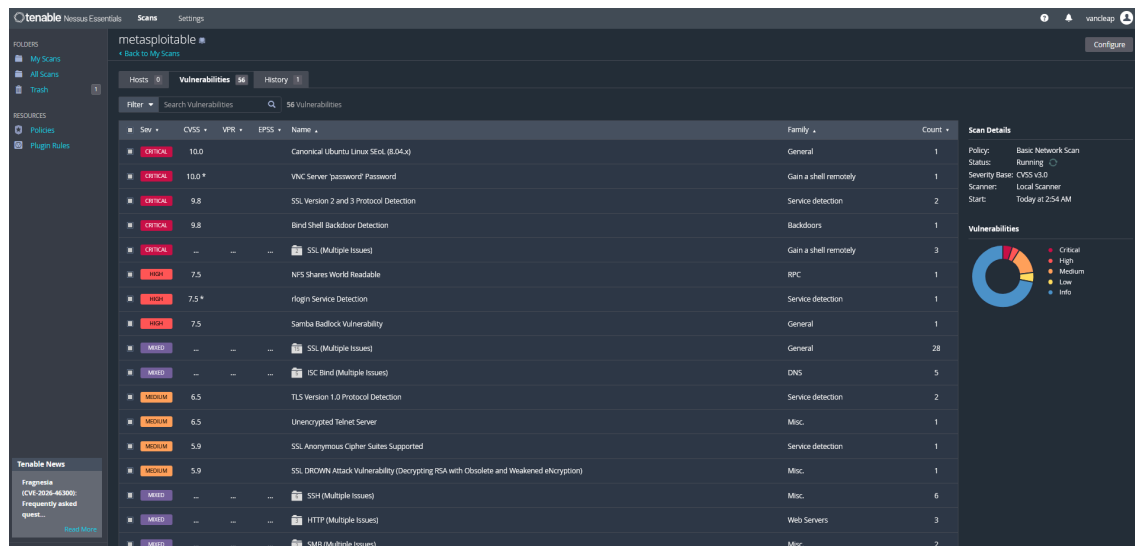
Critical Vulnerabilities - Multiple (Unsupported OS, backdoors, weak authentication, deprecated protocols).

High Vulnerabilities - Several (Samba Badlock, NFS issues).

Physical Assessment:

On-site observations showed significant gaps in physical security controls.

Scan Screenshots:



metasploitable / Plugin #201352

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u/3b0db242e>

Output

```
OS : Ubuntu Linux 8.04
Security End of Life : May 8, 2013
Time since Security End of Life (Est.) : >= 12 years
```

To see debug logs, please visit individual host

Port	Hosts
80/http/www	192.168.56.101

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/H:N/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2:AV:N/AC:L/Au:N/C:C/C/AC

Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux
Unsupported by vendor: true

Tenable News
Microsoft's May 2026 Patch Tuesday Addresses 118 C...
[Read More](#)

metasploitable / Plugin #51988

CRITICAL Bind Shell Backdoor Detection

Description
A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution
Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

```
nessus was able to execute the command "id" using the following request :
```

```
This produced the following truncated output (limited to 10 lines) :
```

```
----- msp -----
root@metasploitable:/# nc -l -p 4444
root@metasploitable:/# nc -l -p 4444
root@metasploitable:/# nc -l -p 4444
----- msp -----
```

To see debug logs, please visit individual host

Port	Hosts
1024/tcp/webshell	192.168.56.101

Plugin Details

Severity: Critical
ID: 51988
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2011
Modified: April 11, 2022

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/H:N/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2:AV:N/AC:L/Au:N/C:C/C/AC

Tenable News
Microsoft Foundry Teaches Her 65 Core Command log...
[Read More](#)

tenable Nessus Essentials Scans Settings

metasploitable / SSL (Multiple Issues)

[Back to Vulnerabilities](#)

Hosts 0 Vulnerabilities 37 History 1

Search Vulnerabilities 15 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
HIGH	7.5			SSL Medium Strength Cipher Suites Supported (SWEET32)	General	2
MEDIUM	6.5			SSL Certificate Cannot Be Trusted	General	2
MEDIUM	6.5			SSL Self-Signed Certificate	General	2
MEDIUM	5.9			SSL RC4 Cipher Suites Supported (Bar Mitzvah)	General	2
MEDIUM	5.3			SSL Certificate Expiry	General	2
MEDIUM	5.3			SSL Certificate with Wrong Hostname	General	2
MEDIUM	5.3			SSL Weak Cipher Suites Supported	General	1
LOW	3.4			SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)	General	2
INFO				SSL Certificate 'commonName' Mismatch	General	2
INFO				SSL Certificate Information	General	2
INFO				SSL Cipher Block Chaining Cipher Suites Supported	General	2
INFO				SSL Cipher Suites Supported	General	2
INFO				SSL Compression Methods Supported	General	2
INFO				SSL Perfect Forward Secrecy Cipher Suites Supported	General	2

Scan Details

Policy: Basic Network Scan
Status: Running
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 2:54 AM

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

Tenable News

Microsoft's May 2026 Patch Tuesday Addresses 118 C...

[Read More](#)

tenable Nessus Essentials Scans Settings

metasploitable / ISC Bind (Multiple Issues)

[Back to Vulnerabilities](#)

Hosts 0 Vulnerabilities 37 History 1

Search Vulnerabilities 5 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
HIGH	8.6			ISC BIND Service Downgrade / Reflected DoS	DNS	1
MEDIUM	6.5			ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS	DNS	1
MEDIUM	5.9			ISC BIND Denial of Service	DNS	1
INFO				DNS Server BIND version Directive Remote Version Detection	DNS	1
INFO				DNS Server hostname.bind Map Hostname Disclosure	DNS	1

Scan Details

Policy: Basic Network Scan
Status: Running
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 2:54 AM

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

Tenable News

Microsoft Foundry Toolkit for VS Code: Command [q]...

[Read More](#)

tenable Nessus Essentials Scans Settings

metasploitable / SSH (Multiple Issues)

Hosts 0 Vulnerabilities 37 History 1

Search Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
MEDIUM	4.3 *			SSH Weak Algorithms Supported	Misc.	1
LOW	3.7			SSH Server CBC Mode Ciphers Enabled	Misc.	1
LOW	3.7			SSH Weak Key Exchange Algorithms Enabled	Misc.	1
LOW	2.6 *			SSH Weak MAC Algorithms Enabled	Misc.	1
INFO				SSH Algorithms and Languages Supported	Misc.	1
INFO				SSH SHA-1 HMAC Algorithms Enabled	Misc.	1

Scan Details

Policy: Basic Network Scan
 Status: Running
 Severity Base: CVSS v3.0
 Scanner: Local Scanner
 Start: Today at 2:54 AM

Vulnerabilities

Tenable News

Microsoft Foundry Toolkit for VS Code: Command Inj...

[Read More](#)

tenable Nessus Essentials Scans Settings

metasploitable / Plugin #32314

Hosts 0 Vulnerabilities 36 History 1

CRITICAL Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Description

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian package removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL, and OpenVPN key material should be re-generated.

See Also

<http://www.tenable.org/uri/0778bdc>
<http://www.tenable.org/uri/144224>

Output

No output recorded.

To see debug logs, please visit individual host

Port	Hosts
22/tcp/ssh	192.168.56.101

Plugin Details

Severity: Critical
 ID: 32314
 Version: 1.2.1
 Type: remote
 Family: Gain a shell remotely
 Published: May 14, 2008
 Modified: July 24, 2024

Risk Information

Risk Factor: Critical
 CVSS v2.0 Base Score: 10.0
 CVSS v2.0 Temporal Score: 8.3
 CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/E:C/A:C
 CVSS v2.0 Temporal Vector: CVSS2#E:F/RL:OR/RC:C

Vulnerability Information

Exploit Available: true
 Exploit Ease: Exploits are available in the news: true

Exploitable With

Core Impact

Reference Information

CWE: 310
 BID: 25179
 CVE: CVE-2008-0166

Tenable News

sgen2 Impinger Certificate Validation

[Read More](#)

Identified Control Gaps

Gap Summary Table

Gap ID	Control ID	Control Name	Evidence Source	Severity	Gap Summary
Physical Control Gaps					
G-01	PE-2	Physical Access Authorizations	Observation	High	Server room is completely open with no restrictions
G-02	PE-3	Physical Access Control	Observation	High	Office doors have no locks or badge access
Technical Control Gaps					
G-03	RA-5	Vulnerability Monitoring and Scanning	Nessus	Critical	56 vulnerabilities detected including multiple critical
G-04	SI-2	Flaw Remediation	Nessus	Critical	Ubuntu 8.04 - End of Life since 2013 (12+ years)
G-05	SI-2	Flaw Remediation	Nessus	Critical	Multiple backdoors present (Bind Shell, etc.)
G-06	CM-6	Configuration Settings	Nessus	Critical	SSL Version 2 and 3 enabled
G-07	CM-7	Least Functionality	Nessus	High	Unnecessary and dangerous services running (Telnet, VNC, etc.)
G-08	IA-7	Cryptographic Module Authentication	Nessus	Critical	VNC Server using default "password" password
G-09	SC-13	Cryptographic Protection	Nessus	Critical	TLS 1.0 and SSLv2/3 protocols supported
G-10	SC-12	Cryptographic Key Establishment	Nessus	High	Weak SSL/TLS configurations and cipher suites
G-11	SI-7	Integrity Monitoring	Nessus	Critical	Multiple remote code execution and privilege escalation vectors

G-12	IA-2	Identification and Authentication	Nessus	Critical	Weak/default authentication mechanisms
Additional Gaps (Nessus Findings)					
G-13	RA-5	Vulnerability Monitoring and Scannign	Nessus	Critical	Unsupported operating system (additional finding)
G-14	CM-7	Least Functionality	Nessus	Medium	Unencrypted Telnet server running
G-15	SC-13	Cryptographic Protection	Nessus	Medium	SSL DROWN attack vulnerability
G-16	CM-6	Configuration Settings	Nessus	Medium	Anonymous cipher suites supported
G-17	SI-7	Integrity Monitoring	Nessus	High	Samba Badlock Vulnerability

Physical Control Gaps:

G-01 – PE-2 Physical Access Authorizations

The on-site physical assessment revealed that the server room at both Summit Ridge Outfitters locations is completely open with no locking mechanism or access restrictions. This directly violates PE-2, which requires physical access to systems and sensitive areas to be restricted to authorized individuals only. **Severity: High.**

If unauthorized individuals gain access to the server room, they could tamper with or steal equipment containing sensitive customer payment card data, employee records, and proprietary product designs. This could lead to data breaches, intellectual property theft, or ransomware deployment.

G-02 – PE-3 Physical Access Control

Physical security observations showed that office doors at both store-front locations have no locks, and there is no badge, key, or any form of access control system in place. This is a clear gap in PE-3 controls, which require physical access controls to prevent unauthorized entry. **Severity: High.**

An attacker could easily enter the offices after hours, access unlocked employee laptops (which also lack password protection), and compromise internal documents, financial information, or the internal network.

Technical Control Gaps:

G-03 – RA-5 Vulnerability Monitoring and Scanning

The Nessus scan identified a total of 56 vulnerabilities on the host system, including multiple Critical severity findings. This demonstrates a significant deficiency in RA-5, which requires organizations to identify and analyze vulnerabilities on host systems. **Severity: Critical.**

Without effective vulnerability monitoring, Summit Ridge Outfitters remains exposed to known exploits that could compromise their website, mobile app backend, or internal systems handling payment card data.

G-04 – SI-2 Flaw Remediation

Nessus detected that the host is running Canonical Ubuntu Linux 8.04.x, which reached end-of-life in May 2013 and has received no security patches for over 12 years. This is a major violation of SI-2, which requires known vulnerabilities to be remediated through patching and updates. **Severity: Critical.**

The business impact is severe, as attackers can use publicly available exploits against this ancient OS to gain full control of systems storing customer data and financial records.

G-05 – SI-2 Flaw Remediation

Multiple backdoors were identified, including the Bind Shell Backdoor. These represent unremediated flaws that allow remote attackers to gain shell access. **Severity: Critical.**

This gap puts Summit Ridge Outfitters at high risk of full system compromise, data exfiltration, and persistent attacker presence on systems containing sensitive design information and payment data.

G-06 – CM-6 Configuration Settings

The scan revealed that SSL Version 2 and SSL Version 3 are enabled on the system. These deprecated protocols violate CM-6 requirements for secure configuration settings. **Severity: Critical.**

Attackers can exploit these weak protocols to intercept or decrypt communications, potentially exposing customer login credentials or payment information transmitted via the company's website or mobile app.

G-07 – CM-7 Least Functionality

The host is running numerous unnecessary and high-risk services including Telnet, VNC, Samba, NFS, and others. This violates CM-7, which requires systems to only run essential services and ports. **Severity: High.**

These extraneous services significantly increase the attack surface, making it easier for attackers to find and exploit entry points into the network.

G-08 – IA-7 Cryptographic Module Authentication

A VNC Server was detected with the default password "password". This is a critical failure of IA-7 controls regarding strong authentication mechanisms. **Severity: Critical.**

An attacker who discovers the VNC service could gain remote graphical access to the system, allowing them to steal data or install malware with minimal effort.

G-09 – SC-13 Cryptographic Protection

The system supports TLS 1.0 along with SSLv2 and SSLv3 protocols. This violates SC-13 requirements for protecting data in transit using strong encryption. **Severity: Critical.**

Sensitive data such as customer payment card information or employee records could be intercepted and decrypted by attackers using well-known protocol downgrade attacks.

G-10 – SC-12 Cryptographic Key Establishment and Management

Nessus identified weak SSL/TLS configurations, including support for anonymous cipher suites and other insecure parameters. **Severity: High.**

This weakness undermines trust in encrypted communications and increases the likelihood of man-in-the-middle attacks targeting the company's online sales platform.

G-11 – SI-7 Integrity Monitoring

Multiple vulnerabilities (including backdoors and remote code execution flaws) allow attackers to modify system files or escalate privileges. This indicates a gap in SI-7 controls for protecting systems from unauthorized modification. **Severity: Critical.**

An attacker could alter system files, install persistent malware, or manipulate financial records without detection.

G-12 – IA-2 Identification and Authentication

The presence of default and weak authentication mechanisms (such as the VNC “password” password) violates IA-2 requirements for proper user identification and authentication. **Severity: Critical.**

This significantly raises the risk of unauthorized access to systems containing confidential business data.

Additional Control Gaps:

G-13 – RA-5 Vulnerability Monitoring and Scanning

In addition to the overall vulnerability count, the host is running an operating system that has been unsupported for over a decade. **Severity: Critical.**

This represents a systemic failure in vulnerability management that could lead to widespread compromise of Summit Ridge Outfitters’ infrastructure.

G-14 – CM-7 Least Functionality

An unencrypted Telnet server is actively running on the system. **Severity: Medium.**

Credentials and commands transmitted via Telnet can be easily captured, giving attackers access to the internal network and sensitive systems.

G-15 – SC-13 Cryptographic Protection

The SSL DROWN Attack Vulnerability was detected, allowing decryption of RSA sessions using obsolete and weakened encryption. **Severity: Medium.**

This could enable attackers to decrypt sensitive sessions between customers and the company’s e-commerce platform.

G-16 – CM-6 Configuration Settings

Anonymous cipher suites are supported, allowing connections without proper authentication or encryption strength. **Severity: Medium.**

This configuration increases the risk of data interception and undermines the confidentiality of customer and business communications.

G-17 – SI-7 Integrity Monitoring

The Samba Badlock Vulnerability (along with other Samba issues) could allow remote attackers to compromise system integrity. **Severity: High.**

Successful exploitation could lead to unauthorized access to shared storage containing internal documents and financial data.

Remediation Plan

Short Term Fixes:

Physical Security Improvements (G-01, G-02)

- Immediately install deadbolt locks on all office doors and the server room.
- Implement a simple badge or keycard access system for sensitive areas.
- Require password locks on all employee laptops.
- Dramatically reduces the risk of unauthorized physical access with minimal cost and effort.

Critical Vulnerability Patching and Isolation (G-04, G-05, G-11, G-13)

- Immediately take the vulnerable host offline or isolate it from the production network.
- Rebuild or replace the outdated Ubuntu 8.04 system with a modern, supported operating system (Ubuntu 22.04 or 24.04 LTS).
- Eliminates the majority of Critical remote code execution and backdoor risks.

Disable Dangerous Services (G-07, G-08, G-12, G-14)

- Disable Telnet, VNC (with default password), and all unnecessary services.
- Change all default credentials and enforce strong password policies.
- Significantly reduces the attack surface within hours.

Secure Cryptographic Configurations (G-06, G-09, G-10, G-15, G-16)

- Disable SSLv2, SSLv3, and TLS 1.0 immediately.
- Enable only TLS 1.2 and TLS 1.3 with strong cipher suites.
- Prevents protocol downgrade and man-in-the-middle attacks on customer data.

Long Term Fixes:

Establish Continuous Vulnerability Management (G-03, G-13)

- Implement regular automated vulnerability scanning (monthly) using a tool such as Nessus or OpenVAS.
- Establish a formal patch management process with defined timelines (Critical within 7 days, High within 30 days).
- Moves the organization from reactive to proactive security posture.

Configuration Hardening and Least Functionality (G-06, G-07, G-16)

- Develop and apply secure baseline configurations for all systems.
- Implement configuration management tools to enforce approved settings.
- Ensures systems only run necessary services and maintain secure configurations over time.

Stronger Authentication and Cryptographic Controls (G-08, G-09, G-10, G-12)

- Deploy multi-factor authentication wherever possible.
- Implement centralized credential management and regular password rotation.
- Adopt modern cryptographic standards across all systems and applications.
- Greatly reduces the risk of credential theft and weak encryption attacks.

Integrity Monitoring and Physical Security (G-01, G-02, G-11, G-17)

- Deploy File Integrity Monitoring (FIM) tools on critical systems.
- Install video surveillance and logging for physical access points.
- Develop and enforce physical security policies with regular audits.
- Provides detection capabilities for both physical and logical tampering.

References:

Easttom, C. (2023). *Computer security fundamentals* (5th ed.). Pearson Education, Inc.

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.SP.800-53r5>

Tenable. (2026). *Nessus vulnerability scanner documentation*.
<https://docs.tenable.com/nessus.htm>

Rapid7. (n.d.). *Metasploitable 2 exploitability guide*.
<https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/>